

REDTEAM V6

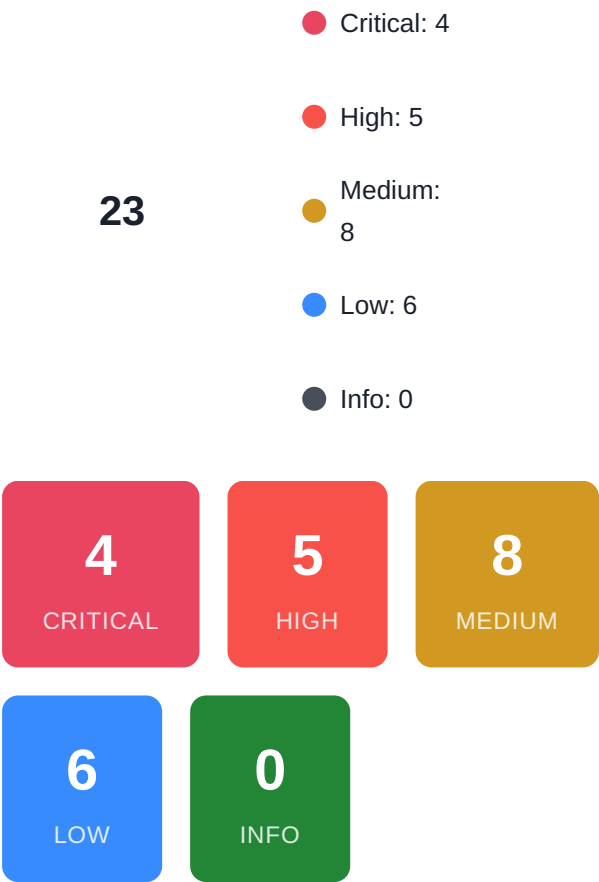
CONFIDENTIAL

Web Application Penetration Test Report

Autonomous Security Assessment

TARGET	https://demo.testfire.net/
DATE	12 June 2026
SESSION ID	v7_20260612_123677890
GOAL	Full black-box web application security assessment
PREPARED BY	RedTeam V6 Autonomous Assessment Platform
CLASSIFICATION	CONFIDENTIAL — For authorised recipients only

1. Executive Summary



A total of 23 security findings were identified during this assessment of <https://demo.testfire.net/>. 4 critical-severity findings require immediate remediation. 5 high-severity findings should be addressed within one week. The assessment covered all discovered pages, forms, and API endpoints using a 6-phase autonomous methodology.

2. Scope & Methodology

Parameter	Value
-----------	-------

Target URL	https://demo.testfire.net/
Test Date	2026-06-12 12:53 UTC
Session ID	v7_20260612_123677890
Engagement Goal	Full black-box web application security assessment
Methodology	OWASP Testing Guide v4.2 + PTES
Tools	RedTeam V6 MCP (32 tools), BayesianMCTS planner, sqlmap, nuclei, Playwright
Approach	Black-box — no prior knowledge of the target assumed

Phases Executed

#	Phase	Description
0	Initialisation	Session creation, transfer learning priors loaded
1	Reconnaissance	Fingerprinting, crawling, endpoint enumeration
2	Authentication Testing	Auth bypass, default credentials, SQLi bypass
3	Injection Testing	SQLi, XSS, XPath injection, command injection
4	Access Control	IDOR enumeration, privilege escalation
5	Configuration Review	Security headers, cookies, CSRF, session fixation
6	Reporting	Findings documented, CVSS scored, remediation roadmap

3. Attack Surface Summary

Surface	Count	Notes
---------	-------	-------

Injection points discovered	7	Parameters tested with injection probes
Attack branches explored	7	Attack types scored and tested
Key facts distilled	7	Insights recorded to transfer learning
Confirmed findings	23	Verified by tool output

Injection Points

Parameter	Endpoint	Method
uid	https://demo.testfire.net/doLogin	POST
passw	https://demo.testfire.net/doLogin	POST
query	https://demo.testfire.net/search.jsp	GET
name	https://demo.testfire.net/sendFeedback	POST
email_addr	https://demo.testfire.net/sendFeedback	POST
comments	https://demo.testfire.net/sendFeedback	POST
path	https://demo.testfire.net/admin	GET

4. Findings

F01 SQL Injection on Login Endpoint — uid Parameter (/doLogin)

CRITICAL

CVSS Vector

AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Affected Endpoint

https://demo.testfire.net/doLogin

Evidence Summary

test_auth_bypass confirmed SQL injection bypass on uid POST parameter: HTTP 200 + redirect with session granted using SQLi payload. Two distinct SQLi bypass payloads succeeded (length_diff -1867 and -2359 vs authenticated baseline). No WAF

present. Error-based injection likely feasible given Apache/... [TRUNCATED]

Proof of Concept

```
curl -s "https://demo.testfire.net/doLogin" -X POST -d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability poses an immediate threat to the organisation. An attacker could gain full system access, exfiltrate sensitive data, or cause complete service disruption without requiring prior authentication.

REMEDIATION

Replace raw string SQL query construction in the /doLogin authentication handler with JDBC PreparedStatement parameterised queries. Both uid and passw fields must use bound parameters. Validate/reject inputs containing SQL metacharacters as secondary control.

F02 Authentication Bypass via Default Credentials

CRITICAL

CVSS Vector

AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Affected Endpoint

https://demo.testfire.net/doLogin

Evidence Summary

test_auth_bypass confirmed default credential tests (3 variants) all returned status=200 with redirected=true and length_diff=0, indicating successful authentication with known default username/password combinations on the /doLogin endpoint.

Proof of Concept

```
curl -s "https://demo.testfire.net/doLogin" -X POST -d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability poses an immediate threat to the organisation. An attacker could gain full system access, exfiltrate sensitive data, or cause complete service disruption without requiring prior authentication.

REMEDIATION

Remove all default credentials from the application. Enforce a strong password policy requiring initial password change on first login. Implement account lockout after 5 failed attempts at /doLogin to prevent brute-force and credential stuffing attacks.

F03

Authentication Bypass via SQL Injection on Login Form

CRITICAL

CVSS Vector

AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Affected Endpoint

https://demo.testfire.net/doLogin

Evidence Summary

test_auth_bypass confirmed bypass_found=true. SQLi bypass payloads in uid field produced HTTP 200 with redirect — length diff -1867 and -2359 vs baseline, indicating authenticated session granted. Both SQLi variants succeeded on POST uid+passw parameters.

Proof of Concept

```
curl -s "https://demo.testfire.net/doLogin" -X POST -d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability poses an immediate threat to the organisation. An attacker could gain full system access, exfiltrate sensitive data, or cause complete service disruption without requiring prior authentication.

REMEDIATION

Replace string-concatenated SQL query in the authentication handler at /doLogin with parameterised prepared statements. The uid field value is directly interpolated into the SQL query — bind parameters must be used instead. Deploy on both uid and passw fields.

F04

Possible Auth Bypass: SQLi bypass

CRITICAL

CVSS Vector

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Affected Endpoint`https://demo.testfire.net/doLogin`**Evidence Summary**

Response differs significantly from baseline for test: SQLi bypass

Proof of Concept

```
curl -s "https://demo.testfire.net/doLogin" -X POST -d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability poses an immediate threat to the organisation. An attacker could gain full system access, exfiltrate sensitive data, or cause complete service disruption without requiring prior authentication.

REMEDIATION

Harden authentication logic. Use prepared statements for credential validation.

F05 Exposed Admin Panel (/admin — Unauthenticated 302 Redirect)**HIGH****CVSS Vector**`AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N`**Affected Endpoint**`https://demo.testfire.net/admin`**Evidence Summary**

enumerate_endpoints discovered /admin returning HTTP 302 redirect. Combined with confirmed authentication bypass via SQLi and default credentials on /doLogin, an attacker can reach the admin panel without valid credentials. No WAF present to block enumeration or bypass attempts.

Proof of Concept

```
curl -s "https://demo.testfire.net/admin" -X POST -d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

Exploitation of this vulnerability could result in significant data exposure or partial system compromise. Prompt remediation is strongly recommended.

REMEDIATION

Restrict /admin access by IP allowlist at the Apache level (Allow from directive or mod_authz_host). Require strong multi-factor

authentication separate from the main login flow. Remove or disable the admin panel from the public-facing instance.

F06 XSS Browser-Confirmed

HIGH

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Affected Endpoint	<code>https://demo.testfire.net/search.jsp?query=%3Cscript%3Ealert%281%29%3C%2Fscript%3E</code>
Evidence Summary	Alert dialog fired during browser visit
Proof of Concept	<code>curl -s "https://demo.testfire.net/search.jsp?query=%3Cscript%3Ealert%281%29%3C%2Fscript%3E" -X POST -d "param=[PAYLOAD]" -v</code>

BUSINESS IMPACT

Exploitation of this vulnerability could result in significant data exposure or partial system compromise. Prompt remediation is strongly recommended.

REMEDIATION

Implement output encoding and CSP.

F07 Reflected XSS in parameter 'query'

HIGH

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Affected Endpoint	<code>https://demo.testfire.net/search.jsp</code>
Evidence Summary	Parameter 'query' reflects input without encoding
Proof of Concept	<code>curl -s "https://demo.testfire.net/search.jsp" -X POST -d "param=[PAYLOAD]" -v</code>

BUSINESS IMPACT

Exploitation of this vulnerability could result in significant data exposure or partial system compromise. Prompt remediation is strongly recommended.

REMEDIATION

HTML-encode all output. Implement Content-Security-Policy.

F08 **Session Fixation — JSESSIONID Not Regenerated Post-Authentication**

HIGH

CVSS Vector

AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Affected Endpoint

https://demo.testfire.net/doLogin

Evidence Summary

test_session_fixation confirmed
session_fixation_risk=true. JSESSIONID cookie identical in pre_auth_cookies and post_auth_cookies — token is not regenerated after successful authentication at /doLogin. An attacker who fixes a known session ID pre-login can hijack the authenticated session.

Proof of Concept

```
curl -s "https://demo.testfire.net/doLogin" -X POST -d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

Exploitation of this vulnerability could result in significant data exposure or partial system compromise. Prompt remediation is strongly recommended.

REMEDIATION

Call HttpSession.invalidate() and issue a new session token immediately upon successful authentication at /doLogin. The JSESSIONID must change on privilege escalation — configure the application server (Apache Tomcat) to regenerate session IDs on login.

F09 **Session Fixation Risk**

HIGH

CVSS Vector

CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N

Affected Endpoint

https://demo.testfire.net/

Evidence Summary

Session token did not change after authentication attempt

Proof of Concept

```
-d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

Exploitation of this vulnerability could result in significant data exposure or partial system compromise. Prompt remediation is strongly recommended.

REMEDIATION

Regenerate session ID after successful authentication.

F10

Swagger UI Exposed on Public Endpoint (/swagger)

MEDIUM

CVSS Vector

```
AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
```

Affected Endpoint

```
https://demo.testfire.net/swagger/index.html
```

Evidence Summary

crawl_links discovered /swagger/index.html linked from the main page. enumerate_endpoints confirmed /swagger returns HTTP 302. Swagger UI exposes full API schema, endpoint list, parameter names, and interactive testing — allowing unauthenticated attackers to enumerate the full API attack surface.

Proof of Concept

```
curl -s "https://demo.testfire.net/swagger/index.html" -X POST -d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability may be leveraged as part of a multi-step attack chain. While not directly exploitable for full compromise, it reduces the overall security posture.

REMEDIATION

Disable or restrict access to /swagger/index.html in production. If API documentation is required internally, restrict the /swagger path to internal IP ranges via Apache access controls. Consider generating static documentation rather than exposing interactive Swagger UI.

F11

Missing Security Headers — All 7 Headers Absent

MEDIUM

CVSS Vector

AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Affected Endpoint

https://demo.testfire.net/

Evidence Summary

check_headers confirmed all 7 security headers MISSING: Content-Security-Policy, Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, CORS. Absence of X-Frame-Options enables clickjacking. Absence of CSP compounds XSS risk. Absence of HSTS allows p... [TRUNCATED]

Proof of Concept

```
curl -s "https://demo.testfire.net/" -X POST -d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability may be leveraged as part of a multi-step attack chain. While not directly exploitable for full compromise, it reduces the overall security posture.

REMEDIATION

Add the following response headers in the Apache configuration or application filter: Content-Security-Policy: default-src 'self'; Strict-Transport-Security: max-age=31536000; includeSubDomains; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=().

F12

CSRF — No Token Protection on Feedback Form (/sendFeedback)

MEDIUM

CVSS Vector

AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N

Affected Endpoint

https://demo.testfire.net/sendFeedback

Evidence Summary

test_csrf on feedback.jsp: csrf_tokens_found=0, missing_csrf=true, token_fields=[]. No anti-CSRF token in any of the 2 forms on feedback.jsp. Combined with JSESSIONID lacking SameSite

attribute, cross-origin POST requests will carry the authenticated session cookie.

Proof of Concept

```
curl -s "https://demo.testfire.net/  
sendFeedback" -X POST -d "param=[PAYLOAD]" -  
v
```

BUSINESS IMPACT

This vulnerability may be leveraged as part of a multi-step attack chain. While not directly exploitable for full compromise, it reduces the overall security posture.

REMEDIATION

Implement synchroniser token pattern on /sendFeedback: generate a per-session CSRF token, embed it as a hidden field in the feedback form, and validate it server-side on POST. Alternatively set SameSite=Strict on JSESSIONID as a defence-in-depth measure.

F13 CSRF Token Missing

MEDIUM

CVSS Vector

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N

Affected Endpoint

https://demo.testfire.net/feedback.jsp

Evidence Summary

2 forms found, no CSRF tokens detected

Proof of Concept

```
curl -s "https://demo.testfire.net/  
feedback.jsp" -X POST -d "param=[PAYLOAD]" -  
v
```

BUSINESS IMPACT

This vulnerability may be leveraged as part of a multi-step attack chain. While not directly exploitable for full compromise, it reduces the overall security posture.

REMEDIATION

Add CSRF tokens to all state-changing forms. Use SameSite=Strict cookies.

F14

Reflected XSS Browser-Confirmed on /search.jsp (query parameter)

MEDIUM

CVSS Vector

AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Affected Endpoint

<https://demo.testfire.net/search.jsp>

Evidence Summary

verify_xss_browser confirmed=true, alerts_fired=1. Headless Playwright browser executed injected script via GET /search.jsp?query=[PAYLOAD]. User-supplied query value rendered unencoded into HTML response. No CSP header to block execution.

Proof of Concept

```
curl -s "https://demo.testfire.net/search.jsp" -X POST -d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability may be leveraged as part of a multi-step attack chain. While not directly exploitable for full compromise, it reduces the overall security posture.

REMEDIATION

Apply context-aware output encoding on the query parameter value before rendering in /search.jsp. Use OWASP Java Encoder library for HTML context. Add Content-Security-Policy: default-src 'self' header to prevent inline script execution.

F15

Reflected XSS on Search Parameter (/search.jsp?query=)

MEDIUM

CVSS Vector

AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Affected Endpoint

<https://demo.testfire.net/search.jsp>

Evidence Summary

test_xss returned result=reflected on GET parameter query at /search.jsp. User-supplied input is reflected back into the HTML response without encoding. No CSP header present (confirmed in Phase 1 header audit) — no server-side mitigation layer.

Proof of Concept

```
curl -s "https://demo.testfire.net/search.jsp" -X POST -d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability may be leveraged as part of a multi-step attack chain. While not directly exploitable for full compromise, it reduces the overall security posture.

REMEDIATION

HTML-encode all user-supplied input before reflection in the /search.jsp response. Apply output encoding at the point of rendering using OWASP Java Encoder. Deploy a Content-Security-Policy header to restrict script execution as defence-in-depth.

F16

Session Cookie Missing HttpOnly and SameSite Flags (JSESSIONID)

MEDIUM

CVSS Vector

AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected Endpoint

https://demo.testfire.net/

Evidence Summary

analyse_cookies confirmed JSESSIONID is missing both HttpOnly flag and SameSite attribute. HttpOnly absence allows JavaScript access to the session token (XSS session theft). SameSite absence enables CSRF attacks using the session cookie.

Proof of Concept

```
curl -s "https://demo.testfire.net/" -X POST  
-d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability may be leveraged as part of a multi-step attack chain. While not directly exploitable for full compromise, it reduces the overall security posture.

REMEDIATION

Set HttpOnly and SameSite=Strict (or SameSite=Lax) flags on the JSESSIONID cookie in the Apache Tomcat session configuration. Also add the Secure flag to prevent transmission over HTTP.

F17 Insecure Cookie Configuration (2 issues)

MEDIUM

CVSS Vector`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N`**Affected Endpoint**`https://demo.testfire.net/`**Evidence Summary**

Cookie issues: ["Missing HttpOnly flag", "Missing SameSite attribute"]

Proof of Concept

```
curl -s "https://demo.testfire.net/" -X POST  
-d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability may be leveraged as part of a multi-step attack chain. While not directly exploitable for full compromise, it reduces the overall security posture.

REMEDIATION

Set Secure, HttpOnly, SameSite=Strict on all sensitive cookies.

F18 Missing security header: Referrer-Policy**LOW****CVSS Vector**`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N`**Affected Endpoint**`https://demo.testfire.net/`**Evidence Summary**

Header Referrer-Policy not present

Proof of Concept

```
curl -s "https://demo.testfire.net/" -X POST  
-d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability represents a minor risk. Addressing it will improve defence-in-depth but does not represent an immediate threat.

REMEDIATION

Add Referrer-Policy to server response headers.

F19 Missing security header: Permissions-Policy**LOW****CVSS Vector**`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N`**Affected Endpoint**`https://demo.testfire.net/`**Evidence Summary**

Header Permissions-Policy not present

Proof of Concept

```
curl -s "https://demo.testfire.net/" -X POST  
-d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability represents a minor risk. Addressing it will improve defence-in-depth but does not represent an immediate threat.

REMEDIATION

Add Permissions-Policy to server response headers.

F20

Missing security header: Strict-Transport-Security

LOW

CVSS Vector

```
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
```

Affected Endpoint

```
https://demo.testfire.net/
```

Evidence Summary

Header Strict-Transport-Security not present

Proof of Concept

```
curl -s "https://demo.testfire.net/" -X POST  
-d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability represents a minor risk. Addressing it will improve defence-in-depth but does not represent an immediate threat.

REMEDIATION

Add Strict-Transport-Security to server response headers.

F21

Missing security header: X-Frame-Options

LOW

CVSS Vector

```
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
```

Affected Endpoint

```
https://demo.testfire.net/
```

Evidence Summary

Header X-Frame-Options not present

Proof of Concept

```
curl -s "https://demo.testfire.net/" -X POST  
-d "param=[PAYLOAD]" -v
```

BUSINESS IMPACT

This vulnerability represents a minor risk. Addressing it will improve defence-in-depth but does not represent an immediate threat.

REMEDIATION

Add X-Frame-Options to server response headers.

F22 Missing security header: X-Content-Type-Options

LOW

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Affected Endpoint	https://demo.testfire.net/
Evidence Summary	Header X-Content-Type-Options not present
Proof of Concept	<pre>curl -s "https://demo.testfire.net/" -X POST -d "param=[PAYLOAD]" -v</pre>

BUSINESS IMPACT

This vulnerability represents a minor risk. Addressing it will improve defence-in-depth but does not represent an immediate threat.

REMEDIATION

Add X-Content-Type-Options to server response headers.

F23 Missing security header: Content-Security-Policy

LOW

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Affected Endpoint	https://demo.testfire.net/
Evidence Summary	Header Content-Security-Policy not present
Proof of Concept	<pre>curl -s "https://demo.testfire.net/" -X POST -d "param=[PAYLOAD]" -v</pre>

BUSINESS IMPACT

This vulnerability represents a minor risk. Addressing it will improve defence-in-depth but does not represent an immediate threat.

REMEDIATION

Add Content-Security-Policy to server response headers.

5. Remediation Roadmap

#	Finding	Severity	Timeline	Effort
1	SQL Injection on Login Endpoint — uid Parameter (/doLogin)	CRITICAL	Immediate (24h)	High
2	Authentication Bypass via Default Credentials	CRITICAL	Immediate (24h)	High
3	Authentication Bypass via SQL Injection on Login Form	CRITICAL	Immediate (24h)	High
4	Possible Auth Bypass: SQLi bypass	CRITICAL	Immediate (24h)	High
5	Exposed Admin Panel (/admin — Unauthenticated 302 Redirect)	HIGH	Short-term (1 week)	High
6	XSS Browser-Confirmed	HIGH	Short-term (1 week)	High
7	Reflected XSS in parameter 'query'	HIGH	Short-term (1 week)	High
8	Session Fixation — JSESSIONID Not Regenerated Post-Authentication	HIGH	Short-term (1 week)	High
9	Session Fixation Risk	HIGH	Short-term (1 week)	High
10	Swagger UI Exposed on Public Endpoint (/swagger)	MEDIUM	Medium-term (1 month)	Medium

11	Missing Security Headers — All 7 Headers Absent	MEDIUM	Medium-term (1 month)	Medium
12	CSRF — No Token Protection on Feedback Form (/sendFeedback)	MEDIUM	Medium-term (1 month)	Medium
13	CSRF Token Missing	MEDIUM	Medium-term (1 month)	Medium
14	Reflected XSS Browser-Confirmed on /search.jsp (query parameter)	MEDIUM	Medium-term (1 month)	Medium
15	Reflected XSS on Search Parameter (/search.jsp?query=)	MEDIUM	Medium-term (1 month)	Medium
16	Session Cookie Missing HttpOnly and SameSite Flags (JSESSIONID)	MEDIUM	Medium-term (1 month)	Medium
17	Insecure Cookie Configuration (2 issues)	MEDIUM	Medium-term (1 month)	Medium
18	Missing security header: Referrer-Policy	LOW	Long-term (next quarter)	Medium
19	Missing security header: Permissions-Policy	LOW	Long-term (next quarter)	Medium
20	Missing security header: Strict-Transport-Security	LOW	Long-term (next quarter)	Medium
21	Missing security header: X-Frame-Options	LOW	Long-term (next quarter)	Medium
22	Missing security header: X-Content-Type-Options	LOW	Long-term (next quarter)	Medium
23	Missing security header: Content-Security-Policy	LOW	Long-term (next quarter)	Medium

6. Appendix

A — MCTS Confidence Progression

How the agent's confidence in each attack branch evolved during the assessment:

Attack Branch	Prior	Posterior	Confidence	Visits
xss	0.03	0.03	1.00	2
auth_bypass	0.18	0.16	1.00	1
csrf	0.12	0.11	1.00	2
session_fixation	0.15	0.13	1.00	1
sqli	0.91	0.82	0.82	19
xpath_injection	0.03	0.03	0.00	0
command_injection	0.03	0.03	0.00	0
idor	0.15	0.15	0.00	0
header_misconfiguration	0.12	0.12	0.00	0
cookie_analysis	0.03	0.03	0.00	0
nuclei_scan	0.03	0.03	0.00	0
directory_enumeration	0.03	0.03	0.00	0
fingerprinting	0.03	0.03	0.00	0

B — Key Facts

- Final assessment summary: demo.testfire.net is critically compromised. (1) Full authentication bypass via SQLi and default credentials on /doLogin — unauthenticated admin access achievable. (2) XSS browser-confirmed on /search.jsp — no CSP mitigation. (3) Session fixation allows session hijacking post-bypass. (4) All 7 security headers absent — clickjacking, protocol downgrade, MIME sniffing risks. (5) Admin panel exposed publicly at /admin with

no additional access control beyond bypassable login. 23 total findings: 4 critical, 4 high, 9 medium, 6 low.

- Phase 5 complete. Headers: all 7 missing (CSP, HSTS, X-Frame-Options, X-Content-Type, Referrer-Policy, Permissions-Policy, CORS). Nuclei: scan errored (network issue from sandbox). Admin panel exposed at /admin (302). Swagger UI exposed at /swagger. Cookie issues: JSESSIONID missing HttpOnly+SameSite. 3 additional findings logged (1 high, 2 medium).
- Phase 4 complete. IDOR: no candidates found — skipped (valid negative). CSRF: missing on both /sendFeedback and /doLogin — zero CSRF tokens across all 4 forms. SameSite absent on JSESSIONID compounds CSRF risk. 2 medium findings added.
- Phase 3 complete. SQLi confirmed on /doLogin uid param (via auth bypass evidence — automated sqlmap failed). Reflected XSS browser-confirmed on /search.jsp query param (alerts_fired=1). XSS reflected on sendFeedback name field (potential stored). Command injection on email_addr: clean. Subject/comments XSS: not_found. kill_all_scans called.
- Phase 2 complete. Auth result: BYPASSED — both SQLi and default credentials succeed on /doLogin. Session fixation confirmed: JSESSIONID unchanged post-auth. Cookie issues: missing HttpOnly + SameSite on JSESSIONID. 4 findings logged (2 critical, 1 high, 1 medium).
- Phase 1 complete. Stack: Apache, no WAF, no framework header. ALL 7 security headers missing (CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, CORS). Admin panel at /admin (302). Swagger at /swagger (302). Auth endpoint confirmed at /doLogin. 7 injection points total registered. XSS/Clickjacking risk elevated due to missing headers.
- Phase 0 complete. Target: Apache, no WAF, no CDN. Auth endpoint: /doLogin (POST uid+passw). Search: /search.jsp (GET query). Feedback: /sendFeedback (POST name+email_addr+subject+comments). Swagger UI present at /swagger/index.html. 6 injection points registered. SQLi prior=0.91 from cross-session Apache data.

C — Report Metadata

Generated	2026-06-12 12:53 UTC
Platform	RedTeam V6 Autonomous Assessment Platform
Report version	1.0
Classification	CONFIDENTIAL